REVISIÓN DE SEGURIDAD · 23/10/2026

Práctica exclusivamente dentro de una red virtual privada sin Internet. El profesor debe confirmar aislamiento y autorización antes de empezar; esta guía no acredita que los servicios o el SOC estén desplegados.
IP_PORTAL = 10.77.0.10. Puertos autorizados: TCP 22,80,139,445,3000,3306,8080. Tu Kali tiene una sola NIC, sin gateway ni DNS, con una IP de 10.77.0.101 a 10.77.0.120 asignada individualmente. Accedes por consola del hipervisor; no cambies tarjetas, rutas ni ACL. No son objetivos tus compañeros, el hipervisor, el SOC, la LAN del centro ni Internet. No pruebes credenciales, explotes, escribas en servicios, ejecutes fuerza bruta o sigas redirecciones fuera del objetivo. Un único proceso activo por alumno; detenerlo al aviso docente o ante errores persistentes.
Se simula una perspectiva externa: no se publica ningún servicio en Internet. Usa nombres bajo tecnoribera.test solo como etiquetas del escenario; los comandos activos apuntan a la IP literal. No hagas consultas DNS/mDNS ni búsquedas públicas durante la práctica. La fase pasiva trabaja con muestras locales marcadas como sintéticas.
Las salidas y tablas del documento son ejemplos didácticos, nunca resultados observados. No copies cifras, versiones, alertas ni conclusiones. Un resultado vacío con error es “no evaluado”, no cero verificado. Si falta instrumentación, anota “no medido”. Las referencias a IP_PORTAL en ejemplos se sustituyen siempre por 10.77.0.10, sin rangos ni comodines.

HE:
ENUMERACION ACTIVA DE TECNORIBERA
RED TEAM BASICO · GUIA PASO A PASO · TRABAJO INDIVIDUAL

Lo primero que te pido: leete el documento entero una vez, de principio a fin, antes de teclear nada. 10 minutos de lectura te ahorran una hora de ir perdido. En seguridad, el que improvisa muere; el que entiende primero y teclea despues, acaba.

Vas a trabajar solo. No es una practica de pareja. Cada uno a su maquina, a su ritmo, con su propia bitacora. Si tu compañero va mas rapido que tu, da igual: tu ritmo es el tuyo. Y si tu vas mas rapido, no soples la respuesta: le estarias quitando el aprendizaje. En este trabajo (como en el curro de verdad), lo que importa es que TU entiendas lo que estas haciendo.

¿Que vamos a hacer tu y yo hoy? Esta es la idea en una frase:

Hasta ayer solo hiciste OSINT pasivo: mirar sin tocar. Hoy damos el salto. Vas a mandarle paquetes al servidor de un cliente ficticio (TECNORIBERA), vas a ver que te contesta, vas a sacar un inventario de lo que expone dentro del laboratorio aislado, Los compañeros de IC analizarán las evidencias locales disponibles. Si no hay sensor o SOC, lo registraréis como no

medido.

Al terminar las 4 horas tienes que poder enseñarme, con capturas y con ficheros guardados en tu portatil:

- Un informe PASIVO del dominio con fuentes y fechas.
- Un inventario ACTIVO (lo que llamamos HE-E10) con cada puerto, servicio, version y evidencia.
- Dos escaneos nmap distintos: uno rapido y uno lento. Comparando los tiempos.
- Resultados de ffuf y nuclei con hallazgos verificados a mano.
- Una tabla de "cuanto ruido he hecho" rellenada con tu compañero de IC.
- Una bitacora limpia con todo documentado por horas.

Si al final tienes todo esto bien, la practica esta hecha. La bitácora es obligatoria; si no existe telemetría, documenta expresamente que el ruido no se ha medido. Soy serio con esto porque en una consultoria real pasa igual: lo que no esta documentado no existe.

TRES REGLAS ANTES DE EMPEZAR
1. Autorización docente y alcance explícito antes de cualquier petición activa.
2. Un cero requiere entrada válida y herramienta funcional; error o falta de acceso se registra como no evaluado.
3. Toda evidencia lleva fuente, fecha/hora y verificación; no copiar conclusiones de ejemplo.

EL ESCENARIO
TECNORIBERA es ficticia. Simulamos enumeración externa de caja gris dentro de una red cerrada. El SOC no forma parte del Compose y su disponibilidad no está acreditada.
Anota número de alumno, IP de tu VM, IP_PORTAL=10.77.0.10, autorización, fecha y horas. El dominio tecnoribera.test es solo una etiqueta. No hay IP_SOC como objetivo autorizado.
DENTRO: enumeración de los siete puertos TCP y rutas de esta guía; lectura del ZIP sintético expresamente indicada; listado anónimo SMB; análisis de evidencias locales.
FUERA: cualquier otra IP, red o puerto; acceso a compañeros o gestión; Internet, DNS público, personas reales, prueba de contraseñas, explotación, fuerza bruta, evasión, modificaciones y denegación de servicio.

LAS HERRAMIENTAS QUE VAMOS A USAR (QUE SON Y PARA QUE SIRVEN)

Antes de teclear nada, te presento el equipo que te he preparado. Lee esto despacio: entender PARA QUE sirve cada una te ahorra mucho tiempo luego.

NMAP — el martillo del pentester.
nmap manda paquetes a los puertos de un servidor y mira que le contestan. Imaginate que vas a un edificio enorme, llamas al timbre de cada piso, y segun quien te abra deduces si vive un

bufete de abogados, una peluqueria o un banco. nmap hace eso con los 65535 puertos de un servidor. Es la herramienta mas usada por atacantes Y por defensores desde 1997. Si solo pudieras llevarte UNA al pentest, llevarias nmap.

SUBFINDER — el detective de subdominios.
Le pasas un dominio (tecnoribera.test) y en 10 segundos pregunta a mas de 20 fuentes publicas (crt.sh, Shodan, VirusTotal, DNSdumpster, archive.org...) y te trae una lista de subdominios que encuentra. Sin tocar al servidor del cliente. Es magia pasiva.

CRT.SH — el registro publico de certificados.
Cada vez que una empresa pide un certificado SSL/TLS para un dominio, la autoridad certificadora (CA) lo publica obligatoriamente en logs publicos (eso se llama "transparencia de certificados" y existe desde 2013). Nosotros consultamos esos logs. Nadie puede ocultar sus subdominios ahi: si pidio cert, se publico. Es LA mejor fuente de subdominios "secretos".

THEHARVESTER — rastreador de correos y hosts.
Igual que subfinder, pero mas enfocado en encontrar correos corporativos y hosts citados en buscadores. En un pentest real, los correos sirven para preparar phishing en la fase de UT6.

WHOIS — quien registro el dominio.
Pregunta publica a los registradores de dominios. Te dice: cuando se registro, quien lo pago, hasta cuando, que nameservers tiene. Antiguamente te daba telefono y email del dueño; ahora con RGPD lo tapan, pero sigue siendo oro para el pentest.

DIG — consultas DNS en linea de comandos.
DNS es la libreta de contactos de internet (traduce nombre -> IP). dig te deja preguntar directamente a los servidores DNS, sin pasar por el navegador. Hoy lo usamos para ver registros MX (correo), NS (quien manda en el DNS) y TXT (donde vive la configuracion anti-phishing: SPF, DMARC, DKIM).

HTTPX — tarjeta de visita rapida de un servidor web.
Le dices "oye, pregunta a esta IP por HTTP" y en 1 segundo te devuelve: titulo HTML, codigo de respuesta, nombre del servidor, tecnologia detectada. Es el "preview" de 10 webs antes de meterte a mirarlas. Rapido, ligero y preciso.

WHATWEB — fingerprint web mas meticuloso.
Mientras httpx es la foto, whatweb es la radiografia. Hace mas peticiones y detecta cosas finas: version concreta de WordPress, nombre del plugin, framework PHP exacto. Mas ruidoso pero mas detallado.

WAFW00F — detector de cortafuegos de aplicacion web.
Comprueba si delante del servidor hay un WAF (Cloudflare, F5, AWS, ModSecurity...). Importa saberlo PORQUE si hay WAF, muchos de tus escaneos siguientes se van a comer un 403 y

vas a pensar que son falsos positivos cuando no lo son. Primero el WAF, despues lo demas.

FFUF — fuzzer de rutas y subdominios.
"Fuzzing" es: le das una lista de palabras (una wordlist) y las prueba todas como rutas o parametros a ver cual existe. Imaginate que tienes un llavero con 5000 llaves y vas probandolas una a una en la puerta hasta ver cual abre. ffuf hace eso: prueba /admin, /login, /backup, /.env, /api, /test... y te apunta las que no son 404. Es como encuentras paginas "ocultas" que no estan linkadas en el menu.

NUCLEI — comprobador masivo de vulnerabilidades conocidas.
nuclei tiene mas de 9000 plantillas publicas, cada una comprueba UN patron concreto: "si esta URL devuelve este codigo con este header, entonces es vulnerable a CVE-X". Puede ejecutar comprobaciones intrusivas o de explotación según la plantilla; esta práctica solo permite las dos plantillas locales de lectura. Es el "escaner" que ves en una pelicula, pero bien hecho: cada plantilla sabe lo que busca y por que. Importante: lo que te diga nuclei lo verificas A MANO siempre.

ENUM4LINUX-NG — cuchillo suizo contra SMB.
Si el servidor expone SMB (puerto 445, lo que en Windows llaman "compartir archivos de red"), enum4linux-ng le hace una docena de preguntas: ¿que shares tienes? ¿que usuarios? ¿que politicas de contraseña? En empresas reales suele estar mal cerrado. Es por donde entra MUCHO atacante.

CURL — cliente HTTP de linea de comandos.
curl manda una peticion HTTP y te enseña la respuesta en bruto. Sin navegador, sin javascript, sin render. Es lo que usamos para VERIFICAR A MANO lo que las herramientas automaticas dicen. Si nuclei dice "/.env expone secretos", tu haces `curl http://IP/.env` y miras con tus ojos si de verdad hay un .env.

Vale, con esta tribu nos vamos a presentar en TECNORIBERA. Al lio.

BLOQUE 0 — PREPARACIÓN OFFLINE Y AUTORIZACIÓN
El profesor prepara Kali, paquetes y herramientas antes de aislar la red, con el objetivo apagado. Durante la práctica no ejecutes apt, actualizaciones de plantillas, consultas públicas ni descargas. Si falta algo, para y avisa: no conectes otra NIC.
Comprueba localmente las versiones:
nmap --version
httpx -version
ffuf -V
nuclei -version
whatweb --version
smbclient --version

Si httpx corresponde a la librería Python, utiliza httpx-toolkit en los comandos. Guarda las versiones en la bitácora y la captura 00-herramientas.png.
Comprueba con ip -br addr e ip route que tu IP es la asignada y no hay ruta por defecto. La verificación de aislamiento definitiva corresponde al profesor y al hipervisor.
CHECKPOINT 0: autorización recibida, herramientas presentes, red correcta y ninguna actualización pendiente durante la sesión.

BLOQUE 1 — CREAR TU CARPETA DE TRABAJO (3 MINUTOS)

MI OBJETIVO: que tengas un sitio ordenado donde van TODAS las evidencias del dia. En un pentest real, si no sabes donde esta cada cosa, lo tienes crudo cuando el cliente te pide pruebas.

Paso 1.1 — Crear la carpeta y entrar.

```
mkdir -p ~/engagement-tecnoribera-$(date +%F)
cd ~/engagement-tecnoribera-$(date +%F)
pwd
```

Lo que esta pasando: `mkdir -p` crea una carpeta (y crea los padres si hace falta). `$(date +%F)` es un truco de bash: se sustituye por la fecha de hoy en formato 2026-10-22. Asi, cuando mañana reabras tu portatil, veras clarisimo cuando lo hiciste. `pwd` imprime donde estas.

Tienes que ver algo tipo:

/home/alumno/engagement-tecnoribera-2026-10-22

Si no, levanta la mano. Un pentester que trabaja en el escritorio del portatil es un pentester que pierde ficheros.

Paso 1.2 — Prepara la bitacora.

```
cat > bitacora.md <<'EOF'
# Bitacora pentest TECNORIBERA

Alumno: <TU NOMBRE>
Fecha: 2026-10-22
Autorización docente/ROE: <RELLENAR SOLO SI EXISTE>
IP_PORTAL asignada: <RELLENAR>
Hora inicio pasivo:
Hora inicio activo:
Hora cierre:
```

Comandos ejecutados (orden cronologico)

EOF

Esto es un "heredoc": todo lo que esta entre `<<'EOF'` y `EOF` se escribe DENTRO del fichero bitacora.md. Es un truco util. Ahora editala con nano para poner tus datos:

nano bitacora.md

Dentro de nano: flechas para moverte, escribes tu nombre y la IP_PORTAL donde pone <RELLENAR>, y guardas con Ctrl+O, Enter, Ctrl+X.

CHECKPOINT 1: ejecuta `ls` y tienes que ver tu bitacora.md. Si no esta, repite el paso.

BLOQUE 2 — RECONOCIMIENTO PASIVO SIMULADO, SIN CONSULTAS EXTERNAS
Objetivo: aprender a registrar fuentes, fechas y límites de una evidencia. Un dominio de laboratorio no tiene por qué existir en certificados públicos, WHOIS o buscadores; sembrar nombres en un archivo local no los publica en subfinder.
Crea esta muestra local, identificada explícitamente como sintética:
cat > muestra-ct.json <<'EOF'
[{"name_value":"portal.tecnoribera.test","origen":"SIMULADO PARA DOCENCIA"},{"name_value":"intra.tecnoribera.test","origen":"SIMULADO PARA DOCENCIA"}]
EOF
jq -r '.[].name_value' muestra-ct.json | sort -u | tee 10-crtsh.txt
printf '[]\n' > muestra-vacia.json
jq -e 'type == "array" and length == 0' muestra-vacia.json
El segundo comando demuestra un array vacío válido en una muestra, NO que crt.sh real haya respondido cero. Un JSON inválido o un error del parser no es count=0.
En pasivo-tecnoribera.md registra: origen “muestra sintética de esta guía”, fecha de la sesión, comando, dos nombres observados y ausencia de comprobación externa. Para subfinder, theHarvester, WHOIS y DNS, crea los entregables 11–16 con la anotación “NO CONSULTADO: red aislada; sin evidencia externa”. No inventes registros MX, SPF o DMARC. La ausencia de información no demuestra suplantación ni entrega de correo.
CHECKPOINT 2: muestra conservada, parser comprobado y resultados separados de lo no evaluado. No se ha enviado ninguna petición pública.

BLOQUE 3 — CONFIRMA EL ALCANCE
Anota autorización, IP asignada a tu VM, IP_PORTAL=10.77.0.10, puertos permitidos y hora de inicio. Si cualquier dato difiere de la pizarra, detente.
Compararemos dos ritmos sobre los mismos siete puertos. Un ritmo lento no garantiza invisibilidad y una categoría de escaneo no garantiza alertas. No fragmentar paquetes ni

introducir técnicas de evasión en esta sesión. Las ACL solo permiten los servicios aprobados.

BLOQUE 4 — DESCUBRIMIENTO Y ESCANEO ACOTADO
Solo tras la confirmación docente y dentro del laboratorio:
nmap -n -Pn -sT -p 80 --max-retries 1 --host-timeout 30s 10.77.0.10 -oA 20-descubrimiento
date -Is
nmap -n -Pn -sT -T3 --max-rate 20 --max-parallelism 1 --max-retries 1 -p 22,80,139,445,3000,3306,8080 10.77.0.10 -oA 21-nmap-rapido
date -Is
-n evita resolución DNS; -Pn omite descubrimiento adicional; -sT utiliza conexión TCP. El límite de ritmo y el único proceso por alumno reducen carga. No usar top-ports, -p-, rangos de IP, UDP ni 443, que no forma parte de esta sesión.
Registra abierto/cerrado/filtrado sin suponer que todo funciona. Si falla, consulta al profesor; no amplíes el alcance.
CHECKPOINT 4: ficheros 20 y 21, hora y captura 02-nmap-rapido.png.

BLOQUE 5 — COMPARACIÓN A MENOR RITMO
date -Is
nmap -n -Pn -sT -T2 --max-rate 2 --max-parallelism 1 --max-retries 1 -p 22,80,139,445,3000,3306,8080 10.77.0.10 -oA 22-nmap-lento
date -Is
Compara los mismos puertos, duración real y estado observado. No atribuyas diferencias al ritmo sin considerar filtrado, carga y errores. No se utiliza fragmentación ni relleno de paquetes.
CHECKPOINT 5: resultados y tiempos reales, sin conclusión de “invisible” por ausencia de alertas.

BLOQUE 6 — VERSIONES Y SCRIPTS APROBADOS
nmap -n -Pn -sT -sV --version-light --max-parallelism 1 --max-rate 10 -p 22,80,139,445,3000,3306,8080 10.77.0.10 -oA 23-nmap-versiones
nmap -n -Pn -sT --script http-title,http-headers --script-timeout 15s -p 80,3000,8080 10.77.0.10 -oA 24-nmap-web-nse
nmap -n -Pn -sT --script smb-os-discovery,smb-security-mode --script-timeout 15s -p 445 10.77.0.10 -oA 25-nmap-smb-nse
Ejecuta los comandos de uno en uno. Los límites de escaneo de puertos no limitan necesariamente todas las peticiones de scripts; por eso se usa una lista explícita corta, revisada por el profesor para la versión instalada.
No usar -sC ni categorías generales: default puede incluir scripts intrusivos. No añadir scripts, credenciales, explotación o descubrimiento de otros hosts.
Un banner de versión no prueba una CVE explotable y las versiones mostradas en ejemplos antiguos no son garantías. Captura 03-nmap-versiones.png y diferencia software observado de contenido simulado.

BLOQUE 7 — FINGERPRINT WEB

printf '%s\n' 'http://10.77.0.10:80' 'http://10.77.0.10:3000' 'http://10.77.0.10:8080' > objetivos-http.txt
httpx -l objetivos-http.txt -title -tech-detect -status-code -server -ip -cl -threads 1 -rate-limit 2 -duc -o 30-httpx.txt
whatweb -a 1 --max-threads 1 --follow-redirect=never http://10.77.0.10/ | tee 31-whatweb.txt
No habilites seguimiento de redirecciones en httpx. Si los flags no existen en tu versión, para y avisa; el profesor debe haber comprobado la ayuda local antes de clase.
La prueba activa con wafw00f se omite en esta edición para mantener un conjunto mínimo de sondas. En 32-wafw00f.txt escribe “NO EJECUTADO en esta sesión; ausencia de WAF no verificada”. No uses HTTPS/443 porque el laboratorio no lo publica.
CHECKPOINT 7: resultados HTTP de los tres servicios y limitaciones documentadas.

BLOQUE 8 — ENUMERACIÓN DE RUTAS CON LÍMITE DE CARGA
Crea una lista corta que permita encontrar las semillas sin miles de peticiones:
cat > rutas-lab.txt <<'EOF'
admin
login
robots.txt
phpinfo.php
backup.zip
.env
.git/HEAD
.git/config
internal
no-existe-control
EOF
ffuf -u http://10.77.0.10/FUZZ -w rutas-lab.txt -t 1 -rate 2 -timeout 5 -maxtime 120 -mc 200,204,301,302,307,401,403 -o 40-ffuf-rutas.json
No añadas -r, recursión, otros hosts ni fuzzing DNS. Un 403/301 aislado no demuestra existencia: compara la ruta de control y el contenido.
Verifica manualmente, de una en una, sin -L:
curl --noproxy '*' --max-time 5 -sS http://10.77.0.10/robots.txt
curl --noproxy '*' --max-time 5 -sS http://10.77.0.10/.env
curl --noproxy '*' --max-time 5 -sS http://10.77.0.10/.git/HEAD
curl --noproxy '*' --max-time 5 -sS http://10.77.0.10/phpinfo.php
curl --noproxy '*' --max-time 5 -sS -o backup.zip http://10.77.0.10/backup.zip
unzip -l backup.zip
El ZIP es una muestra docente; esta descarga concreta está autorizada. No ejecutes su contenido ni pruebes sus credenciales. phpinfo es una página HTML simulada, no prueba de PHP operativo. HEAD/config expuestos no prueban recuperación del repositorio completo.
El bloque DNS opcional queda omitido; documenta “sin servicio DNS en esta configuración”.
CHECKPOINT 8: captura 04-ffuf.png y al menos tres verificaciones manuales, o incidencia concreta si no se reproducen.

BLOQUE 9 — NUCLEI CON DOS PLANTILLAS LOCALES REVISABLES
La severidad no indica si una plantilla es inocua. No ejecutar todo el catálogo, filtros globales por severidad, workflows, code, headless, fuzzing ni OAST. Usar exclusivamente estas dos plantillas locales de lectura; no incluir otras en el directorio.

```
mkdir -p plantillas-tecnoribera
cat > plantillas-tecnoribera/git-head.yaml <<'EOF'
id: tecnoribera-git-head
info:
  name: TECNORIBERA - HEAD sintetico expuesto
  author: docente
  severity: info
http:
  - method: GET
    path:
      - "{{BaseURL}}/.git/HEAD"
    redirects: false
    matchers-condition: and
    matchers:
      - type: status
        status: [200]
      - type: word
        part: body
        words: ["ref: refs/heads/"]
EOF
cat > plantillas-tecnoribera/dotenv.yaml <<'EOF'
id: tecnoribera-dotenv
info:
  name: TECNORIBERA - credencial sintetica expuesta
  author: docente
  severity: high
http:
  - method: GET
    path:
      - "{{BaseURL}}/.env"
    redirects: false
    matchers-condition: and
    matchers:
      - type: status
        status: [200]
      - type: word
        part: body
        words: ["DB_PASSWORD="]
```

EOF
Validación local, sin solicitudes al objetivo:
nuclei -validate -t plantillas-tecnoribera/git-head.yaml -t plantillas-tecnoribera/dotenv.yaml -duc
Si falla, detener el bloque. Cuando el profesor autorice las pruebas dentro del laboratorio:
nuclei -u http://10.77.0.10 -t plantillas-tecnoribera/git-head.yaml -rl 2 -c 1 -bs 1 -timeout 5 -retries 0 -ni -duc -o 50-nuclei-base.txt
nuclei -u http://10.77.0.10 -t plantillas-tecnoribera/dotenv.yaml -rl 2 -c 1 -bs 1 -timeout 5 -retries 0 -ni -duc -o 51-nuclei-criticos.txt
-ni desactiva Interactsh y -duc las comprobaciones de actualización. No cargar configuración personal con proxies, destinos o plantillas adicionales; el profesor debe entregar un perfil limpio offline. El fichero 51 conserva su nombre por compatibilidad, pero esta prueba tiene severidad high, no exige resultados critical.
CHECKPOINT 9: conservar ambos resultados y verificar con curl cada hallazgo. Si no hay coincidencias, documentarlo; no inventar dos críticos para cumplir un mínimo.

BLOQUE 10 — ENUMERACIÓN SMB DE LECTURA
smbclient -N -L //10.77.0.10 | tee 60-smb.txt
smbclient -N //10.77.0.10/publico -c 'ls' | tee 61-smb-publico.txt
Se sustituye enum4linux-ng -A por estas dos operaciones explícitas de listado anónimo, sin passwords, RID cycling ni pruebas de autenticación. No instalar nada durante la sesión. No subir, descargar, borrar ni modificar archivos de la share. El profesor ha configurado acceso de solo lectura.
CHECKPOINT 10: share y listado observados o error exacto. No dar por garantizados usuarios concretos. Si 445 está cerrado/filtrado, anotar que el bloque no pudo evaluarse.

BLOQUE 11 — ROJO/AZUL: MEDICIÓN HONESTA Y LOCAL
El Compose no incluye Wazuh ni un sensor de red. No apuntar agentes al SOC real del centro ni abrir salida para ello. Para esta sesión, el profesor puede exportar por consola los logs locales de portal y servicios una vez finalizada la actividad y entregarlos a IC. Los SYN no aparecen necesariamente en logs web; para medirlos hace falta captura/sensor dentro del laboratorio, preparado y autorizado aparte.
Con 20 alumnos simultáneos, correlacionar IP de origen y tiempos. Las comparaciones de una técnica se realizan por turnos; una cifra agregada no se atribuye a un alumno sin evidencia.
En 70-medicion-ruido.md usa columnas: técnica, IP origen, inicio/fin, duración, fuente de telemetría, eventos/alertas observados, regla si existe, limitaciones. Para lo no instrumentado escribe “NO MEDIDO”, nunca cero. “Sin alertas” no significa “sin tráfico” ni “indetectable”.
No se garantizan reglas, niveles o tiempos de Wazuh. La conclusión debe describir observaciones reales y sus límites; no copiar ejemplos de detección.
CHECKPOINT 11: tabla trazable o limitación explícita. La falta de SOC no obliga a inventar mediciones y no invalida por sí sola la enumeración.

BLOQUE 12 — EL INVENTARIO HE-E10 (EL ENTREGABLE PRINCIPAL, 15 MINUTOS)

MI OBJETIVO: consolidar lo encontrado en una tabla que un cliente pueda leer sin saber de tus herramientas.

Paso 12.1 — Crea inventario-HE-E10.md con esta estructura:
Fecha/hora: <sesión real>
Alumno e IP origen: <rellenar>
Alcance: 10.77.0.10; TCP 22,80,139,445,3000,3306,8080
Autorización/ROE: <referencia real, no marcar OK sin verificar>
Resumen: servicios observados, exposiciones sintéticas verificadas y limitaciones.
Tabla: host | puerto | protocolo | servicio | versión observada | hallazgo | comando/evidencia | fecha/hora | verificado/no verificable/falso positivo.
Añade apartados de falsos positivos, incidencias y puntos no evaluados. No rellenes filas con las versiones de los ejemplos. En phpinfo/Git/ZIP distingue contenido sintético de software realmente ejecutado. El banner antiguo no demuestra explotación. La falta de telemetría no prueba un punto ciego del SOC.
CHECKPOINT 12: todas las filas basadas en evidencia, sin mínimo de hallazgos inventado.

BLOQUE 13 — HIGIENE Y ENTREGA (10 MINUTOS)

MI OBJETIVO: que termines dejando todo ordenado y me entregues un tar.gz.

Paso 13.1 — Cierra lo que esta abierto.

exit # cierra sesiones ssh (no deberias tener ninguna, pero por si acaso)

Paso 13.2 — Comprueba que esta todo.

ls -la

Deberias ver, al menos:

00-herramientas.png
10-crtsh.txt ... 16-dns-txt.txt
20-descubrimiento.* 21-nmap-rapido.* 22-nmap-lento.* 23-nmap-versiones.*
24-nmap-web-nse.* (si procede) 25-nmap-smb-nse.* (si procede)
30-httpx.txt 31-whatweb.txt 32-wafw00f.txt
40-ffuf-rutas.json (41-ffuf-subs.json si lo hiciste)
50-nuclei-base.txt 51-nuclei-criticos.txt
60-smb.txt y 61-smb-publico.txt (o error/no evaluado)
70-medicion-ruido.md
pasivo-tecnoribera.md inventario-HE-E10.md bitacora.md
02-nmap-rapido.png 03-nmap-versiones.png 04-ffuf.png (al menos 5 capturas)

Paso 13.3 — Avisame del cierre.

Antes de hacer el tar, dime en voz alta: "Yo, [tu nombre], termino el pentest contra IP_PORTAL a las HH:MM. Declaro los comandos realizados y cualquier error o incidente; las comprobaciones técnicas de cierre corresponden al profesor." Esta frase es la cadena de responsabilidad.

Paso 13.4 — Empaqueta.

```
cd ~
tar czf engagement-tecnoribera-$(date +%F)-NN.tar.gz engagement-tecnoribera-$(date +%F)/
```

Donde NN es tu numero de alumno. La entrega se hace mediante el mecanismo docente autorizado después de cerrar la práctica. No añadas conectividad a la VM aislada: el profesor puede recoger el archivo por consola/exportación offline y subirlo desde el entorno habitual.

SI ALGO FALLA DURANTE LA CLASE

Antes de pedirme ayuda, tienes que tener respuestas a estas 5 preguntas:

1. ¿Que comando ejecutaste? (copia-pega exacto, no "lance nmap")
2. ¿Que te devolvio? (copia-pega exacto, no "no sale nada")
3. ¿Que esperabas que ocurriera?
4. ¿Que has mirado para resolverlo tu?
5. ¿Que has probado tu mismo antes de llamarme?